

Narrativa Explicativa de la Encuesta

La presente encuesta nace de una sospecha razonable: que muchas organizaciones hablan de métricas de ciberseguridad, pero pocas podrían describir, sin sonrojarse, la fórmula de más de tres de ellas.

Inspirados por NIST SP 800-55 y acompañados por la alegre severidad del marco regulatorio europeo, proponemos un instrumento que pretende algo insólito: que las cifras que llenan los informes de ciberseguridad sirvan para tomar decisiones y no solo para decorar comités.

1. Espíritu general

Más que un examen, la encuesta es un espejo.

Su misión no es humillar a organizaciones bienintencionadas, sino ayudarles a responder a preguntas incómodas: ¿por qué medimos lo que medimos?, ¿quién ha decidido que estos indicadores son los correctos?, ¿qué ocurre cuando la realidad contradice sistemáticamente nuestras métricas triunfalistas?

La ironía, aquí, no es un adorno estilístico, sino una defensa frente al riesgo de convertir las métricas en un ritual vacío.

2. Relación con NIST SP 800-55

NIST recuerda que una métrica es útil si y solo si puede asociarse a una decisión concreta: más inversión, menos inversión, rediseño de un control, cambio de proveedor, modificación de un proceso.

La encuesta traduce este principio en preguntas operativas.

Cada bloque está diseñado para identificar si la organización:

- Ha definido objetivos claros.
- Ha seleccionado métricas coherentes con esos objetivos.
- Dispone de datos razonables para alimentar esas métricas.
- Utiliza los resultados en foros de decisión donde de verdad se mueve el presupuesto.

Si la respuesta a cualquiera de estos puntos es negativa, no pasa nada: eso también es un resultado, y probablemente un punto de partida más honesto que cualquier semáforo en verde.

3. El contexto español y europeo

El ENS, NIS2 y las obligaciones de notificación a CERTs nacionales han añadido capas de estructura (y de papeleo) a la vida de las organizaciones.

La encuesta asume este contexto y lo aprovecha: muchas de las preguntas se apoyan en controles, obligaciones de reporte y procesos que ya son familiares para quienes conviven con ENS, RGPD y compañía.

La idea es sencilla: no inventar un mundo nuevo de indicadores, sino ordenar y aprovechar mejor los datos que la organización ya se ha visto obligada a producir.

4. El papel del índice global de madurez (IGM)

En algún momento, alguien pedirá "un número".

Para ese momento, la encuesta incluye elementos suficientes para construir un Índice Global de Madurez (IGM) que agregue dimensiones de gobernanza, controles, cultura, impacto y alineamiento normativo.

La tentación será usar ese número como arma arrojadiza.

La propuesta, en cambio, es utilizarlo como herramienta de conversación: un punto de partida para entender dónde se concentran las debilidades y qué mejoras son razonables en el corto y medio plazo.

5. Sobre el ROI y otros animales mitológicos

Hablar de ROI en ciberseguridad es arriesgado: la mitad del negocio consiste en evitar lo que, por definición, no ocurre.

Aun así, la encuesta pregunta por modelos de coste, de pérdidas evitadas y de priorización basada en riesgo, porque renunciar a medir la eficiencia es aceptar que la ciberseguridad es un agujero negro presupuestario.

El mensaje implícito es: no hace falta una precisión quirúrgica, pero sí un esfuerzo intelectual serio por cuantificar, aunque sea aproximado, qué se gana y qué se evita con cada euro invertido.

6. Cómo leer los resultados sin perder la fe

Al analizar los resultados, es probable que aparezcan incoherencias: organizaciones que se declaran muy maduras en marcos de referencia pero que confiesan no medir tiempos de detección; presupuestos generosos sin métricas de impacto; Zero Trust autoproclamado sin segmentación ni MFA generalizado.

Lejos de ser un fracaso, estas contradicciones son una radiografía útil.

La encuesta está diseñada precisamente para hacer visible la brecha entre el discurso y la práctica, y para orientar la conversación hacia dónde se necesita invertir talento, tiempo y presupuesto.

7. Conclusión abierta

En un mundo ideal, las métricas de ciberseguridad serían pocas, claras, compartidas y aburridamente estables.

En el mundo real, la combinación de innovación tecnológica, regulación inquieta y creatividad del adversario garantiza que los indicadores deberán evolucionar.

La encuesta que aquí se presenta no pretende congelar la realidad, sino ofrecer un marco vivo en el que las organizaciones puedan medir su propio progreso, sin perder del todo el sentido del humor.